

CyberSOC Platform

Security Audit & SOC 2 Compliance Checklist

Phase 3: Go-Live Roadmap Execution

Document Type	Security Compliance Framework
Version	1.0.0 - Audit Ready
Classification	Confidential - Security Sensitive
Date	2026-08-26
Framework Alignment	SOC 2 Type II, ISO 27001, NIST CSF
Audit Scope	CyberSOC Platform Production Environment

Table of Contents

1. Executive Summary — Security posture overview and compliance objectives
2. Control Framework Mapping — SOC 2 TSC criteria alignment matrix
3. Access Control Security — CC6: Logical and physical access controls
4. System Integrity Controls — CC7: System integrity and change management
5. Data Protection — CC6.7: Data encryption and privacy controls
6. Availability Management — CC1: System availability and BCP/DR
7. Incident Response — CC7.4: Security incident handling procedures
8. Vulnerability Management — Continuous security assessment program
9. Network Security Architecture — Defense-in-depth network controls
10. Logging and Monitoring — CC7.2: Comprehensive audit trail
11. Third-Party Risk Management — Vendor security assessment framework
12. Audit Evidence Collection — Documentation and artifact requirements
13. Gap Analysis Summary — Remediation tracking and status
14. Appendices — Reference materials and supporting evidence

1. Executive Summary

This Security Audit and SOC 2 Compliance Checklist provides a comprehensive assessment framework for validating the CyberSOC Platform's security controls against industry-standard criteria including SOC 2 Trust Services Criteria (TSC), ISO 27001:2022 control domains, NIST Cybersecurity Framework functions, and CIS Critical Security Controls. The document serves as both an internal validation tool for pre-audit readiness and as evidence documentation support material for external auditor examination during SOC 2 Type II attestation engagement.

1.1 Security Posture Assessment Overview

The CyberSOC Platform has been architected with security-first principles embedded throughout the development lifecycle, from threat modeling during design phases through continuous security testing in production environments. The platform implements defense-in-depth strategies across all layers including perimeter security, network segmentation, identity and access management, application-level controls, data protection mechanisms, and operational security procedures. This layered approach ensures that compromise of any single control does not result in complete security failure, aligning with zero-trust architecture principles recommended by NIST SP 800-207 and implemented throughout the platform's service mesh integration and microservice communication patterns.

1.2 Compliance Objectives and Scope

The primary compliance objective for this assessment cycle is achieving SOC 2 Type II attestation covering the Security, Availability, and Confidentiality Trust Service Categories over a minimum observation period of six months. Secondary objectives include maintaining alignment with ISO 27001:2022 certification requirements for customers requiring international standard compliance mapping, and demonstrating NIST Cybersecurity Framework maturity at Level 3 (Defined) across Identify, Protect, Detect, Respond, and Recover function areas. The assessment scope encompasses the production Kubernetes cluster hosting all CyberSOC platform components, underlying cloud infrastructure (AWS/GCP/Azure depending on deployment target), identity providers integrated for authentication, third-party services for data processing or storage, and administrative interfaces used by operations personnel.

1.3 Overall Compliance Status Dashboard

Trust Service Category	Controls Assessed	Passing	Partial	Failing	Compliance %
Security (Common Criteria)	87	79	6	2	90.8%
Availability (CC1)	24	22	2	0	91.7%
Confidentiality (CC6)	35	32	3	0	91.4%
Processing Integrity (CC7)	28	25	2	1	89.3%
Privacy (Appendix B)	19	17	2	0	89.5%

Trust Service Category	Controls Assessed	Passing	Partial	Failing	Compliance %
OVERALL STATUS	193	175	15	3	90.7%

Table 1.1: Executive Compliance Status Summary

2. Control Framework Mapping

This section provides detailed mapping between CyberSOC Platform security controls and the criteria established by multiple compliance frameworks, enabling auditors to trace specific platform implementations to required control objectives. The mapping demonstrates how individual technical configurations, procedural controls, and organizational policies collectively satisfy framework requirements. Cross-walk tables identify primary control ownership, evidence artifacts available for examination, and any compensating controls implemented where direct criterion satisfaction requires alternative approaches due to architectural constraints or environmental factors.

2.1 SOC 2 Trust Services Criteria Mapping

SOC 2 reporting criteria are organized into Common Criteria (applicable to all trust service categories) and Additional Criteria specific to Security, Availability, Processing Integrity, Confidentiality, and Privacy categories. The following table maps each applicable criterion to corresponding CyberSOC Platform controls, providing the foundation for control testing procedures executed during audit examination periods.

SOC 2 Criterion	Control Description	Control ID	Status	Evidence Reference
CC1.1: Environmental Protection	Physical access controls, fire suppression	ENV-001	PASS	Data center SOC 2 report
CC2.1: Access Authority	Role-based access control implementation	ACC-001	PASS	RBAC policy documents
CC2.2: System Account Provisioning	Automated user lifecycle management	ACC-002	PARTIAL	Okta integration logs
CC3.2: System Boundary Defense	Network firewall rules, WAF deployment	NET-001	PASS	AWS Security Group configs
CC4.1: Data Input Validation	API schema validation, input sanitization	APP-001	PASS	OpenAPI specifications
CC6.1: Confidentiality of Data	Encryption at rest and in transit	ENC-001	PASS	TLS certificates, KMS keys
CC6.2: Data Transfer Security	Mutual TLS, certificate pinning	ENC-002	PASS	Istio mTLS policies
CC6.3: Public Key Management	Certificate lifecycle automation	ENC-003	PASS	Cert-manager configuration
CC6.6: Data Disposal	Secure deletion procedures	OPS-008	PARTIAL	Data retention policy
CC6.7: Data Integrity	Checksum verification, tamper detection	DBT-001	PASS	Database WAL logs
CC7.1: Change Management	GitOps deployment pipeline	DEV-001	PASS	ArgoCD audit logs
CC7.2: System Monitoring	Prometheus/Grafana observability	MON-001	PASS	Dashboard screenshots

SOC 2 Criterion	Control Description	Control ID	Status	Evidence Reference
CC7.3: Incident Response	IR playbooks, on-call procedures	INC-001	PARTIAL	Incident tickets, post-mortems
CC7.4: Vendor Management	Third-party risk assessments	VND-001	FAIL	Pending vendor audits

Table 2.1: SOC 2 Trust Services Criteria to Control Mapping

2.2 NIST Cybersecurity Framework Alignment

The NIST Cybersecurity Framework (NIST CSF) provides a flexible structure for managing cybersecurity risk across five core functions: Identify, Protect, Detect, Respond, and Recover. Each function contains categories and subcategories mapped to CyberSOC Platform capabilities, demonstrating comprehensive coverage of cybersecurity best practices recognized globally across industries and regulatory contexts.

NIST Function	Category	Subcategory	Implementation	Maturity
Identify (ID)	Asset Management	ID.AM-1	CMDB auto-discovery	Level 3
Identify (ID)	Risk Assessment	ID.RA-1	Quarterly risk reviews	Level 3
Protect (PR)	Access Control	PR.AC-1	IAM with MFA enforcement	Level 4
Protect (PR)	Data Security	PR.DS-1	AES-256 encryption	Level 4
Protect (PR)	Maintenance	PR.MA-2	Patch within 72 hours	Level 3
Detect (DE)	Anomaly Detection	DE.AE-1	SIEM correlation rules	Level 3
Detect (DE)	Monitoring	DP.CM-1	24/7 NOC monitoring	Level 4
Respond (RS)	Response Plan	RS.RP-1	Documented IR procedures	Level 3
Recover (RC)	Recovery Plan	RC.RP-1	DR tested quarterly	Level 3

Table 2.2: NIST CSF Function Coverage Matrix

3. Access Control Security (CC6)

Access control represents one of the most critical security domains for the CyberSOC Platform, given its role in processing sensitive security event data, incident details, and customer configuration information. The platform implements a comprehensive Identity and Access Management (IAM) framework integrating multiple authentication factors, fine-grained authorization policies, session management controls, and privileged access management for administrative functions. This section details each access control layer with implementation specifics, configuration parameters, and audit evidence demonstrating control effectiveness.

3.1 Authentication Mechanisms

The CyberSOC Platform supports multiple authentication protocols to accommodate diverse customer integration requirements while maintaining consistent security standards across all entry points. Primary authentication flows through OAuth 2.0 / OpenID Connect integration with enterprise identity providers including Okta, Azure Active Directory, and Google Workspace. Multi-factor authentication (MFA) is mandatory for all human users accessing administrative interfaces, with support for TOTP (Time-based One-Time Password), FIDO2/WebAuthn hardware tokens, and push notification approvals via mobile authenticator applications. Service-to-service authentication utilizes mutual TLS certificates issued through the Istio service mesh Certificate Authority, with short-lived certificates (24-hour validity) automatically rotated without service interruption.

Control ID	Control Description	Implementation	Test Procedure	Status
ACC-001	MFA Enforcement	Okta Adaptive MFA policy	Attempt login without MFA	PASS
ACC-002	Password Policy	Min 14 chars, complexity reqs	Create weak password	PASS
ACC-003	Session Timeout	15 min idle, 8 hr absolute	Wait for timeout	PASS
ACC-004	Account Lockout	5 failed attempts, 30 min lock	Trigger lockout	PASS
ACC-005	Password History	Prevent last 12 passwords	Reuse old password	PASS
ACC-006	Service Auth (mTLS)	Istio strict mTLS mode	Inspect traffic	PASS
ACC-007	API Key Rotation	90-day max age, auto-expire	Check key ages	PARTIAL
ACC-008	SSO Integration	SAML 2.0, OIDC compliant	IdP-initiated login	PASS

Table 3.1: Authentication Controls Assessment

3.2 Authorization and Role-Based Access Control

Authorization decisions follow the principle of least privilege, granting users and service accounts only the minimum permissions necessary to perform their assigned functions. The role-based access control (RBAC) model defines four hierarchical roles (Super Administrator, Organization Administrator, Analyst, Read-Only Viewer) with distinct permission sets scoped to organizational boundaries in multi-tenant deployments. Resource-level permissions enable granular access control to specific modules (Threat Detection, SIEM, Case Management, Compliance) and operations (create, read, update, delete, export). Attribute-Based Access Control (ABAC) extensions enable dynamic policy evaluation based on data classification levels, geographic restrictions, and time-of-day constraints for highly sensitive operations.

Permission	Super Admin	Org Admin	Analyst	Viewer
User Management	Full CRUD	Own Org Users	Read Only	None
System Configuration	Full CRUD	Limited	None	None
Threat Intelligence	Full CRUD	Full CRUD	CRUD Own	Read Only
SIEM Event Access	All Data	Org Data	Org Data	Aggregated

Permission	Super Admin	Org Admin	Analyst	Viewer
Case Management	All Cases	Org Cases	Assigned	Read Only
Compliance Reports	Generate + Export	Generate	View	View
API Key Management	Full CRUD	Own Keys	None	None
Audit Log Access	Full Access	Org Logs	Own Actions	None
Billing Administration	Full Access	Own Org	None	None

Table 3.2: RBAC Permission Matrix by Role

3.3 Privileged Access Management

Privileged accounts representing elevated risk due to their extensive system access undergo additional security controls beyond standard user account protections. Just-in-time (JIT) privilege elevation grants temporary administrative access for documented change windows, automatically revoking privileges upon expiration. All privileged sessions record full video capture and keystroke logging for forensic analysis and compliance auditing. Break-glass emergency access procedures enable urgent privilege escalation during critical incidents with enhanced approval requirements and automatic post-access review triggers. The platform integrates with enterprise Privileged Access Management (PAM) solutions including CyberArk and HashiCorp Vault for centralized credential brokering and session recording.

Control ID	Control Requirement	Implementation Details	Evidence	Status
PAM-001	JIT Privilege Elevation	Max 4-hour sessions, auto-revoke	Vault audit logs	PASS
PAM-002	Session Recording	Full video + keystroke log	Recording archives	PASS
PAM-003	Break-Glass Procedure	MFA + manager approval	Emergency access logs	PARTIAL
PAM-004	Credential Rotation	Service accounts every 90 days	Rotation schedule	PASS
PAM-005	Shared Account Elimination	Individual accountability	Account inventory	PASS

Table 3.3: Privileged Access Management Controls

4. System Integrity Controls (CC7)

System integrity controls ensure that CyberSOC Platform software, configurations, and data remain protected against unauthorized modification throughout their lifecycle. These controls span from secure software development practices preventing code tampering through immutable infrastructure definitions preventing runtime drift, to cryptographic integrity verification ensuring data has not been altered in transit or at rest. Change management procedures provide structured processes for authorized modifications while maintaining audit trails sufficient to reconstruct system state at any point in time.

4.1 Software Development Lifecycle Security

The Secure Software Development Lifecycle (SSDLC) integrates security activities into each phase of software development, from initial threat modeling through production deployment and ongoing maintenance. Source code resides in Git repositories with branch protection rules requiring pull request review from at least one peer before merging to protected branches. Automated security scanning executes on every commit including static application security testing (SAST) using Semgrep and Checkmarx, dynamic application security testing (DAST) using OWASP ZAP in staging environments, and software composition analysis (SCA) using Snyk for dependency vulnerability detection. Container images undergo vulnerability scanning before registry promotion using Trivy, with defined severity thresholds blocking images containing CRITICAL or HIGH severity CVEs affecting executable packages.

Phase	Security Activity	Tool/Process	Gate Criteria	Status
Design	Threat Modeling	STRIDE methodology	Model approved	PASS
Development	SAST Scanning	Semgrep, Checkmarx	Zero HIGH/CRIT	PASS
Development	Secret Detection	GitLeaks, TruffleHog	Zero secrets	PASS
CI Pipeline	Dependency Scan	Snyk, Dependabot	Patch < 7 days	PASS
CI Pipeline	Container Scan	Trivy Grype	Block CRITICAL	PASS
Staging	DAST Testing	OWASP ZAP	Zero OWASP Top 10	PARTIAL
Production	IAST/RASP	Contrast Security	Runtime protection	PASS
Release	Code Signing	Cosign signatures	Signed images only	PASS

Table 4.1: SSDLC Security Gate Controls

4.2 Change Management Procedures

All changes to production systems follow formal change management procedures balancing agility requirements with stability and auditability needs. Changes are categorized by risk level (Standard, Normal, Emergency) with corresponding approval workflows and testing requirements. Standard changes follow pre-approved runbooks with automated deployment through GitOps pipelines (ArgoCD) applying declarative Kubernetes manifests from version-controlled repositories. Normal changes require change advisory board (CAB) review for non-trivial modifications affecting multiple system components or introducing new dependencies. Emergency changes accommodate urgent security patches or production incident remediation with streamlined approval and enhanced post-implementation review requirements.

Change Type	Approval Required	Testing Required	Deployment Window	Rollback Plan
Standard	Auto-approved (runbook)	Automated tests pass	Any time (auto)	Automatic
Normal	CAB approval (1 day lead)	Full regression suite	Change window	Required

Change Type	Approval Required	Testing Required	Deployment Window	Rollback Plan
Emergency	CAB chair + 2 approvers	Smoke test only	Immediate	Mandatory
Security Patch	Security team lead	Vulnerability validation	< 24 hours	Required
Hotfix	On-call + tech lead	Targeted test	Immediate	Required

Table 4.2: Change Classification Matrix

5. Data Protection Controls (CC6.7)

Data protection controls safeguard sensitive information processed by the CyberSOC Platform throughout its lifecycle from creation through ultimate disposal. The platform handles multiple data sensitivity classifications including publicly anonymized threat intelligence, confidential customer configuration data, restricted security event details, and highly sensitive incident response information potentially containing personally identifiable information (PII), payment card data subject to PCI-DSS, or protected health information under HIPAA for healthcare sector customers. Encryption, tokenization, masking, and access controls combine to provide defense-in-depth data protection appropriate to each classification level.

5.1 Encryption Implementation

Encryption protects data confidentiality both at rest (stored data) and in transit (data moving between system components or to external parties). The platform employs AES-256 symmetric encryption for data at rest using envelope encryption patterns where data encryption keys (DEK) are themselves encrypted by key encryption keys (KEK) managed by cloud provider Key Management Service (AWS KMS, Google Cloud KMS, or Azure Key Vault). TLS 1.3 with strong cipher suites secures data in transit, with mutual TLS (mTLS) enforced for all inter-service communication via Istio service mesh integration. Database field-level encryption applies to particularly sensitive columns (credentials, API keys, personal identifiers) using application-layer encryption transparent to the database engine.

Data State	Algorithm	Key Management	Key Rotation	Compliance
Rest - Block Storage	AES-256-GCM	AWS KMS CMK	Annual	FIPS 140-2 L3
Rest - Database	AES-256-CBC	Envelope encryption	90 days	PCI-DSS v4.0
Rest - Object Storage	AES-256	SSE-KMS / SSE-S3	Annual	SOC 2 CC6.1
Transit - External	TLS 1.3	ACM / Let's Encrypt	Auto (< 60d)	NIST SP 800-52
Transit - Internal	mTLS (Istio)	Istio CA	24 hours	Zero Trust
Application Field	AES-256-GCM	HashiCorp Vault	180 days	Custom
Backup	AES-256	Backup-specific KEK	Annual	GDPR Art. 32

Table 5.1: Encryption Implementation Matrix

5.2 Data Classification and Handling

Data classification provides the foundation for applying appropriate protection controls based on information sensitivity and regulatory requirements. The CyberSOC Platform implements a four-tier classification scheme aligned with NIST SP 800-53 and ISO 27001 recommendations, with clear labeling requirements, handling procedures, and retention schedules for each tier. Automated classification tools assist users in assigning correct classifications, with machine learning models suggesting classifications based on content analysis and manual override capability for edge cases requiring human judgment.

Classification	Description	Examples	Access Control	Retention
PUBLIC	No sensitivity, freely distributed	Marketing materials, docs	Unrestricted	Indefinite
INTERNAL	Business use, not for external	Internal reports, procedures	Authenticated users	3 years
CONFIDENTIAL	Sensitive business information	Customer config, contracts	Need-to-know basis	7 years
RESTRICTED	Highly sensitive, regulated data	PII, credentials, incidents	Named individuals	Regulatory min

Table 5.2: Data Classification Scheme

6. Availability Management (CC1)

Availability management ensures the CyberSOC Platform meets committed service level agreements (SLAs) for uptime accessibility, minimizing downtime impact on customer security operations dependent on continuous platform availability. The platform targets 99.95% availability SLA (approximately 4.38 hours maximum unplanned downtime annually), achieved through redundant architecture across multiple availability zones, automated failover mechanisms, proactive capacity planning, and rapid incident response procedures. Business continuity planning addresses extended outage scenarios where normal recovery procedures prove insufficient.

6.1 High Availability Architecture

High availability architecture eliminates single points of failure through redundancy at every system layer. Application components deploy with minimum three replicas distributed across availability zones using Kubernetes pod anti-affinity rules preventing co-location on single nodes. Load balancers distribute traffic across healthy endpoints with health check validation removing degraded instances from rotation. Database clusters operate in high-availability configurations with synchronous replication to standby nodes ready for automatic failover upon primary detection. Caching layers use Redis Cluster with automatic shard failover, and search infrastructure leverages Elasticsearch cross-cluster replication for query serving continuity.

Component	HA Configuration	Failover Time	RPO	SLA Target
API Gateway	3+ replicas, NLB	< 30 seconds	N/A (stateless)	99.99%

Component	HA Configuration	Failover Time	RPO	SLA Target
Authentication	2+ replicas, sticky session	< 60 seconds	< 5 minutes	99.95%
Threat Engine	5+ replicas, queue-based	< 90 seconds	< 1 minute	99.9%
PostgreSQL	3-node CNPG cluster	< 30 seconds (auto)	< 5 seconds	99.95%
Redis Cluster	6 nodes (3M+3R)	< 10 seconds	< 1 minute	99.99%
Elasticsearch	5 nodes, hot-warm	< 60 seconds	< 5 seconds	99.9%

Table 6.1: High Availability Configuration by Component

6.2 Business Continuity and Disaster Recovery

Business Continuity Planning (BCP) and Disaster Recovery (DR) preparations address scenarios exceeding normal high availability failover capabilities, including entire region outages, natural disasters affecting data center facilities, or catastrophic data corruption events. The DR strategy employs active-passive multi-region architecture with continuously replicated standby environment capable of assuming production workload within defined Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO). Annual DR exercises validate procedure effectiveness and identify improvement opportunities, with tabletop exercises conducted quarterly for scenario familiarization.

Scenario	Impact Scope	RTO Target	RPO Target	Last Test Date	Result
Single AZ Failure	1/3 capacity loss	< 5 min (auto)	Zero	2024-Q3	PASS
Region Outage	Complete site loss	< 15 minutes	< 5 minutes	2024-Q2	PASS
Data Corruption	Logical data loss	< 1 hour	< 5 minutes	2024-Q1	PASS
Ransomware	Encrypted data	< 4 hours	< 1 hour	2024-Q2	PARTIAL
Vendor Failure	Cloud provider down	< 24 hours	< 1 hour	Tabletop only	N/A

Table 6.2: Disaster Recovery Scenario Matrix

7. Incident Response Procedures (CC7.4)

Incident Response (IR) capabilities represent the platform's ability to detect, contain, eradicate, and recover from security incidents while minimizing business impact and preserving forensic evidence. As a security operations platform, CyberSOC's own IR procedures must exemplify the practices recommended to customers, demonstrating operational excellence in security incident handling. The IR program follows NIST SP 800-61 guidelines with Computer Security Incident Response Team (CSIRT) structure, defined escalation paths, communication templates, and continuous improvement through lessons learned integration.

7.1 Incident Classification and Severity

Incident classification enables appropriate resource allocation and escalation based on potential business impact. The severity scale ranges from SEV-1 (critical, immediate executive visibility required) through SEV-4 (low, normal queue processing) with defined criteria, response time objectives (RTO), and communication requirements for each level. Automatic classification assistance from SIEM correlation rules suggests initial severity based on detected indicators, with human analyst validation and adjustment authority to prevent both under-response to serious incidents and alert fatigue from excessive SEV elevations.

Severity	Definition	Example	Response SLA	Escalation
SEV-1 (Critical)	Active breach, data exfiltration	Ransomware, intrusion	15 minutes	CISO + CEO
SEV-2 (High)	Major service degradation	Production outage	1 hour	VP Engineering
SEV-3 (Medium)	Limited impact, contained	Single component issue	4 hours	Team Lead
SEV-4 (Low)	Minimal impact, workaround exists	Non-critical bug	24 hours	On-call engineer
SEV-5 (Informational)	No immediate action needed	Security advisory	Next sprint	Backlog

Table 7.1: Incident Severity Classification

7.2 Incident Response Playbooks

Documented playbooks provide step-by-step guidance for common incident types, ensuring consistent response execution regardless of which analyst handles the incident. Playbooks incorporate decision trees for scenario branching, command references for investigation actions, communication templates for stakeholder notifications, and evidence preservation procedures supporting potential legal proceedings. Regular playbook testing through tabletop exercises and simulated incidents validates accuracy and identifies updates required due to system changes or evolving threat landscape.

Playbook Name	Scope	Owner	Last Updated	Test Frequency
Malware/Ransomware	Endpoint compromise	IR Lead	2024-Q3	Quarterly
Data Breach/Exfiltration	Data loss incident	DPO + IR Lead	2024-Q2	Bi-annually
DDoS Attack	Availability threat	NetSec Team	2024-Q3	Quarterly
Insider Threat	Unauthorized access	HR + IR Lead	2024-Q1	Annually
Supply Chain Compromise	Third-party breach	Vendor Mgmt	2024-Q2	Annually
Credential Compromise	Account takeover	IAM Team	2024-Q3	Quarterly

Table 7.2: Incident Response Playbook Inventory

8. Vulnerability Management Program

The Vulnerability Management Program provides systematic identification, prioritization, remediation, and tracking of security vulnerabilities across all CyberSOC Platform components including container images, host operating systems, application dependencies, and infrastructure configurations. The program balances thoroughness (comprehensive scanning coverage) with efficiency (focused remediation on highest-risk vulnerabilities) through risk-based prioritization incorporating CVSS scores, exploitability intelligence, asset criticality, and exposure factors. Continuous scanning集成到 CI/CD pipelines ensures new vulnerabilities are detected rapidly, while scheduled comprehensive scans provide baseline assurance of coverage completeness.

8.1 Vulnerability Scanning Coverage

Multiple scanning tools address different vulnerability categories and technology stacks, providing defense-in-depth detection capability where no single tool achieves complete coverage. Container image scanning with Trivy and Gype identifies known CVEs in base OS packages and application dependencies before deployment. Dynamic application security testing (DAST) with OWASP ZAP discovers runtime vulnerabilities not visible in static analysis including authentication flaws, access control bypasses, and injection points. Infrastructure-as-code scanning with Checkov and tfsec detects misconfigurations in Kubernetes manifests, Terraform definitions, and cloud resource templates before infrastructure provisioning.

Scan Type	Tool	Frequency	Coverage	Integration
Container Image	Trivy, Gype	Every build + daily	OS + deps	CI/CD gate
SAST	Semgrep, SonarQube	Every commit	Source code	PR comments
DAST	OWASP ZAP	Staging deploys	Running app	Pipeline stage
Dependency	Snyk, Dependabot	Daily + on publish	Libraries	Auto PRs
Infrastructure	Checkov, tfsec	Every IaC change	K8s, Cloud	Plan validation
Secrets	GitLeaks, TruffleHog	Every commit	Repo history	Pre-push hook
Runtime RASP	Contrast Security	Continuous	Production	Alerting

Table 8.1: Vulnerability Scanning Tool Matrix

8.2 Remediation SLAs by Severity

Remediation Service Level Agreements establish maximum allowable timeframes for addressing vulnerabilities based on severity classification, balancing security urgency against operational disruption from emergency changes. Critical and High severity vulnerabilities require expedited patching with shortened change approval cycles, while Medium and Low severity vulnerabilities enter normal release cadences to accumulate in planned maintenance windows. Exceptions to SLA timelines require documented risk acceptance from designated approvers specifying compensating controls mitigating risk during extended exposure period.

Severity	CVSS Range	Remediation SLA	Extension Process	Exception Approver
Critical	9.0 - 10.0	72 hours	CISO approval (max +48h)	CISO
High	7.0 - 8.9	7 calendar days	Security Lead (max +7d)	VP Engineering
Medium	4.0 - 6.9	30 calendar days	Team Lead (max +14d)	Director
Low	0.1 - 3.9	90 calendar days	Manager (max +30d)	Manager
Informational	0.0	Best effort	N/A	N/A

Table 8.2: Vulnerability Remediation SLAs

9. Network Security Architecture

Network security architecture implements defense-in-depth protection for CyberSOC Platform communications, controlling traffic flow between trust zones, detecting and blocking malicious network activity, and enabling secure remote access for administrative functions. The architecture follows zero-trust principles where no network location is inherently trusted; all communication requires authentication and authorization regardless of source location within traditional perimeter boundaries. Software-defined networking through Kubernetes NetworkPolicy resources and Istio service mesh provides granular traffic control impossible with traditional hardware-centric network security approaches.

9.1 Network Segmentation

Network segmentation divides the platform into distinct security zones with controlled traffic flow between zones, limiting lateral movement potential for attackers who compromise assets in lower-trust zones. The primary segmentation boundary separates public-facing components (API Gateway, frontend) from internal application workloads (threat engine, SIEM core) from data stores (PostgreSQL, Redis, Elasticsearch) from management interfaces (monitoring, debugging endpoints). Each zone enforces default-deny ingress policies with explicitly permitted traffic flows documented in the network architecture diagram maintained in the security documentation repository.

Security Zone	Components	Trust Level	Ingress Policy	Egress Policy
DMZ	Gateway, Frontend, WAF	Low (Internet-facing)	From Internet only	To App Zone only
Application	Auth, Threat, SIEM, Cases	Medium	From DMZ only	To Data + Ext
Data	PostgreSQL, Redis, ES	High	From App Zone only	Backup egress
Management	Prometheus, Grafana, K8s API	High	VPN + Bastion only	To all zones (read)
External	IdPs, SaaS integrations	Varies	App Zone initiated	Per integration

Table 9.1: Network Security Zones

9.2 Perimeter Security Controls

Perimeter security controls protect the platform boundary where external traffic enters the trusted environment, implementing the first line of defense against internet-based threats. Cloud provider load balancers terminate TLS connections using strong cipher suites and forward decrypted traffic to Web Application Firewall (WAF) rules inspecting HTTP payloads for attack patterns including SQL injection, cross-site scripting, and path traversal attempts. Rate limiting at the edge prevents volumetric denial-of-service attacks from overwhelming backend infrastructure, while geo-blocking rules restrict access from high-risk geographic regions per customer configuration preferences.

Control	Technology	Configuration	Protection Against	Status
DDoS Mitigation	CloudFlare/Shield	Auto-detect + mitigate	Volumetric attacks	ACTIVE
WAF	AWS WAF / ModSecurity	OWASP Core Rule Set	App-layer attacks	ACTIVE
Rate Limiting	API Gateway	1000 req/min/IP	Abuse, brute force	ACTIVE
Geo-Blocking	Cloud CDN	Customer-configurable	High-risk regions	CONFIGURABLE
Bot Protection	reCAPTCHA Enterprise	Score-based challenge	Automated abuse	ACTIVE
TLS Termination	ALB/NLB + ACM	TLS 1.3 only	Eavesdropping	ACTIVE

Table 9.2: Perimeter Security Control Stack

10. Logging and Monitoring (CC7.2)

Comprehensive logging and monitoring provide the audit trail, operational visibility, and anomaly detection capabilities essential for security control effectiveness demonstration and incident response support. The logging strategy captures events across multiple dimensions including authentication attempts, authorization decisions, data access operations, system configuration changes, application errors, and performance metrics. Centralized log aggregation enables correlation across distributed microservices, while long-term retention satisfies regulatory requirements and supports historical forensic investigations.

10.1 Log Sources and Retention

Log sources span infrastructure, platform, and application layers providing comprehensive visibility into system behavior. Infrastructure logs from Kubernetes audit logging capture all API server requests including authentication, authorization, admission control decisions, and resource mutations. Platform logs from Istio service mesh record inter-service communication including request/response metadata, latency measurements, and error conditions. Application logs from CyberSOC components capture business-relevant events including user actions, threat detections, case status changes, and compliance violations. Security-specific logs from authentication systems, WAF, and endpoint protection provide focused visibility into security-relevant activity.

Log Category	Source	Format	Retention	Access Control
Audit Trail	Kubernetes API Server	JSON	2 years online + 3 cold	Security team only
Auth Events	Okta/Azure AD	Syslog/CEF	1 year	IAM + Security
App Logs	CyberSOC Components	Structured JSON	90 days hot, 1 year cold	App teams
Mesh Telemetry	Envoy/Istio	Access logs	30 days	Platform team
Security Events	WAF, IDS/IPS	CEF format	1 year	SOC analysts
DB Audit	PostgreSQL pgAudit	CSV	2 years	DBA + Security
Change Logs	Git/ArgoCD	Git history	Indefinite	All engineers

Table 10.1: Log Source Inventory and Retention

10.2 Security Monitoring and Alerting

Security monitoring transforms raw log data into actionable intelligence through correlation rule engines, behavioral analytics, and threshold-based alerting. The SIEM platform (integrated CyberSOC component or external solution such as Splunk or SentinelOne) processes normalized security events against detection rules identifying suspicious activity patterns indicative of compromise. Alert prioritization incorporates asset criticality, threat intelligence context, and user risk scoring to surface highest-fidelity alerts for analyst investigation while suppressing noise from benign activity matching rule patterns but lacking malicious intent indicators.

Alert Category	Detection Method	Priority	Response Owner	MTTR Target
Brute Force Login	Auth log correlation	P1	IAM Team	< 15 minutes
Privilege Escalation	CloudTrail analysis	P1	Security Ops	< 15 minutes
Data Exfiltration	DLP rules	P1	IR Team	< 30 minutes
Malware Detection	EDR alerts	P1	Endpoint Team	< 30 minutes
Policy Violation	CASB/CWPP rules	P2	GRC Team	< 4 hours
Anomalous Access	UEBA baseline deviation	P2	SOC Analysts	< 4 hours
Config Drift	IaC comparison	P3	Platform Team	< 24 hours

Table 10.2: Security Alert Categories and Response

11. Third-Party Risk Management

Third-party risk management (TPRM) addresses security risks introduced by vendors, suppliers, and service providers whose products, services, or data handling affect CyberSOC Platform security posture or customer data protection. The TPRM program classifies third parties by

criticality and data access level, applies proportional due diligence requirements, establishes contractual security obligations, and conducts ongoing monitoring for deteriorating risk posture. Critical vendors undergo annual security assessments using standardized questionnaires (SIG, CAIQ) supplemented by independent audit report review (SOC 2 Type II, ISO 27001 certification) where available.

11.1 Vendor Tier Classification

Vendor classification determines the depth of due diligence and ongoing monitoring applied to each third-party relationship. Tier 1 (Critical) vendors handle sensitive customer data, provide security-critical infrastructure, or could cause significant business impact if compromised or unavailable. Tier 2 (Important) vendors support business operations with limited data access or provide non-critical infrastructure components. Tier 3 (Standard) vendors pose minimal security risk with no data access or limited business impact potential. Classification occurs during vendor onboarding with periodic re-evaluation triggered by scope changes or risk indicator detection.

Tier	Criteria	Examples	Assessment Req	Review Frequency
Tier 1 - Critical	PHI/PCI data, infra-critical	Cloud provider, IdP, DB host	Full assessment + audit	Annual + continuous
Tier 2 - Important	Internal data, ops dependency	Monitoring, backup, CDN	Questionnaire only	Bi-annual
Tier 3 - Standard	No data, easily replaceable	Office tools, utilities	Self-certification	Tri-annual

Table 11.1: Vendor Tier Classification Framework

12. Audit Evidence Collection

Successful SOC 2 Type II attestation requires comprehensive evidence demonstrating control operation effectiveness throughout the observation period (minimum 6 months, typically 12 months). This section catalogs evidence artifacts available for each control domain, specifies artifact formats acceptable to auditors, identifies evidence owners responsible for collection and retention, and provides sample evidence packages demonstrating expected documentation quality. Evidence organization follows the control framework structure enabling efficient auditor navigation between criteria and supporting documentation.

12.1 Evidence Requirements by Domain

Domain	Evidence Type	Format	Location	Responsible Party
Access Control	Access review reports	PDF export	Confluence/GRC tool	IAM Team
Access Control	MFA enrollment stats	IdP dashboard screenshots	Okta/Azure portal	IAM Team
Access Control	Terminated access verification	Spreadsheet + screenshots	HRIS + IdP logs	HR + IAM
Change Mgmt	Approved change records	Jira/ServiceNow export	Change mgmt system	Release Mgr

Domain	Evidence Type	Format	Location	Responsible Party
Change Mgmt	Deployment audit logs	ArgoCD/GitLab exports	GitOps platform	DevOps
Change Mgmt	CAB meeting minutes	Meeting notes + recordings	SharePoint/Confluence	CAB Chair
Encryption	Certificate inventory	Script output + config	cert-manager status	Platform Team
Encryption	Key rotation logs	KMS CloudTrail	AWS/GCP console	Security Eng
Backup	Restore test results	Test execution records	Runbook docs	SRE Team
Incident Response	Incident tickets	PagerDuty/Jira export	Incident mgmt system	IR Lead
Monitoring	Alert acknowledgment	PagerDuty/on-call logs	Observability stack	NOC Team

Table 12.1: Evidence Artifact Requirements

13. Gap Analysis and Remediation Tracking

Gap analysis identifies control deficiencies requiring remediation before achieving full compliance with target frameworks. Each gap receives a unique identifier, severity rating based on compliance and risk impact, assigned owner accountable for remediation delivery, target completion date aligned with audit timeline requirements, and current status tracking progress toward closure. Gaps classified as blockers (preventing audit issuance) receive highest priority with executive visibility and dedicated resources; gaps classified as observations (documented findings not preventing issuance) enter normal backlog prioritization.

13.1 Current Gap Inventory

Gap ID	Control Affected	Description	Severity	Owner	Target Date	Status
GAP-001	CC7.4 (IR)	Missing tabletop exercise docs	Medium	IR Lead	2024-11-15	In Progress
GAP-002	CC6.6 (Disposal)	Data retention policy gaps	Low	DPO	2024-12-01	Open
GAP-003	Vendor Mgmt	Tier 1 vendor audit overdue	Critical	Procurement	2024-10-30	Overdue
GAP-004	CC7.2 (Monitor)	Log retention < 1 yr for some	Medium	Platform	2024-11-30	Planning
GAP-005	Access (ACC-007)	API key rotation not automated	High	IAM Team	2024-11-15	In Progress
GAP-006	DAST Coverage	API endpoints untested	Medium	AppSec	2024-12-15	Open
GAP-007	DR Test	Ransomware scenario partial	High	SRE Lead	2024-11-01	In Progress

Table 13.1: Active Gap Inventory

13.2 Remediation Timeline and Milestones

Remediation timeline coordinates gap closures with upcoming audit milestones, ensuring all critical and high-severity gaps resolve before auditor evidence collection begins. Weekly gap review meetings track progress, identify blockers requiring escalation, and adjust timelines when original estimates prove optimistic. The current roadmap targets all critical gap resolution by end of Q4 2024, enabling Q1 2025 audit kickoff with clean control environment. Contingency plans address risk of delayed gap closure including compensating control implementation, scope exclusion requests (with customer acceptance), and qualified opinion acceptance for residual gaps.

Milestone	Date	Dependencies	Success Criteria
Critical Gaps Closed	2024-10-31	Resource allocation	GAP-003 resolved
High Gaps Closed	2024-11-30	Dev complete, testing	GAP-005, GAP-007 done
Medium Gaps Closed	2024-12-15	Normal sprint work	GAP-001, GAP-004, GAP-006
Evidence Package Complete	2025-01-15	All gaps closed	Auditor-ready artifacts
Audit Kickoff	2025-02-01	Contract signed	Fieldwork begins
Attestation Issuance	2025-05-01	Clean opinion	SOC 2 report received

Table 13.2: Remediation Milestone Schedule

14. Appendices

Appendices provide supplementary reference materials supporting the main body of this compliance checklist. These materials include glossary definitions for technical and compliance terminology, contact information for control owners and subject matter experts, links to external framework documentation referenced throughout the assessment, and template documents for evidence collection activities. Auditors may reference appendix materials for clarification but should rely primarily on main body content for control assessment conclusions.

14.1 Glossary of Terms

Term	Definition
SOC 2	Service Organization Control 2 - AICPA attestation framework for service organizations
Trust Services Criteria (TSC)	2016 criteria organized by category for SOC 2 examinations
CC (Common Criteria)	Control criteria applicable to all SOC 2 trust service categories
Type I	Point-in-time assessment of control existence at a specified date
Type II	Assessment of control operating effectiveness over a defined period (min 6 months)
RTO	Recovery Time Objective - Maximum acceptable downtime after disruption

Term	Definition
RPO	Recovery Point Objective - Maximum acceptable data loss measured in time
mTLS	Mutual TLS - Two-way TLS authentication where both parties present certificates
SIEM	Security Information and Event Management - Log correlation and analysis platform
DLP	Data Loss Prevention - Technology preventing unauthorized data exfiltration
CASB	Cloud Access Security Broker - Proxy controlling cloud service access
UEBA	User and Entity Behavior Analytics - ML-based anomaly detection
CVSS	Common Vulnerability Scoring System - Standardized severity ratings (0-10)
CAB	Change Advisory Board - Body reviewing and approving significant changes

Table 14.1: Compliance Terminology Glossary

14.2 Document Control Information

Attribute	Value
Document Title	CyberSOC Platform Security Audit & SOC 2 Compliance Checklist
Document Number	CYBERSOC-SEC-001
Version	1.0.0
Classification	Confidential - Security Sensitive
Author	CyberSOC Security Architecture Team
Reviewer	CISO, VP Engineering, GRC Manager
Approval Authority	Chief Information Security Officer
Effective Date	2026-08-26
Review Cycle	Quarterly or upon significant change
Next Review Date	2025-01-15
Distribution	Internal - Security, Engineering, GRC Teams

Table 14.2: Document Control Information